

TEMA 2.- FUNDAMENTOS EN SEGURIDAD DIGITAL

Criptografía

Escritura Oculta

Según la RAE: “Arte de escribir de modo oculto o enigmático”

Criptología: “ciencia que se ocupa de garantizar la privacidad en el almacenamiento y la transmisión de información”.

Criptoanálisis: “conjunto de técnicas destinadas a restituir la información cifrada a su estado original, desconociendo la clave o método de cifrado”

Texto Claro (plaintext) + Clave = Texto cifrado (ciphertext)

Objetivo de la Criptografía:

Proporcionar las dimensiones de la seguridad que configuran la **privacidad**

Autenticación, Confidencialidad, Integridad, No Repudio, Trazabilidad, Temporalidad

Mediante estándares abiertos y eficaces

Algo de Historia

Babilonia: Escítalo

Roma: Método de César (13 caracteres)

Imperio Español: “La clave” (sílabas, terminaciones, letras)

Siglo XIX: máquinas de rotores

II Guerra Mundial: Sigaba (USA), Purple (Japón), Enigma (Alemania) – Alan Turing

SZ40 (Lorenz) – su criptoanálisis (Colossus, Max Newman) primer computador electrónico (1500 válvulas)

Conceptos Básicos

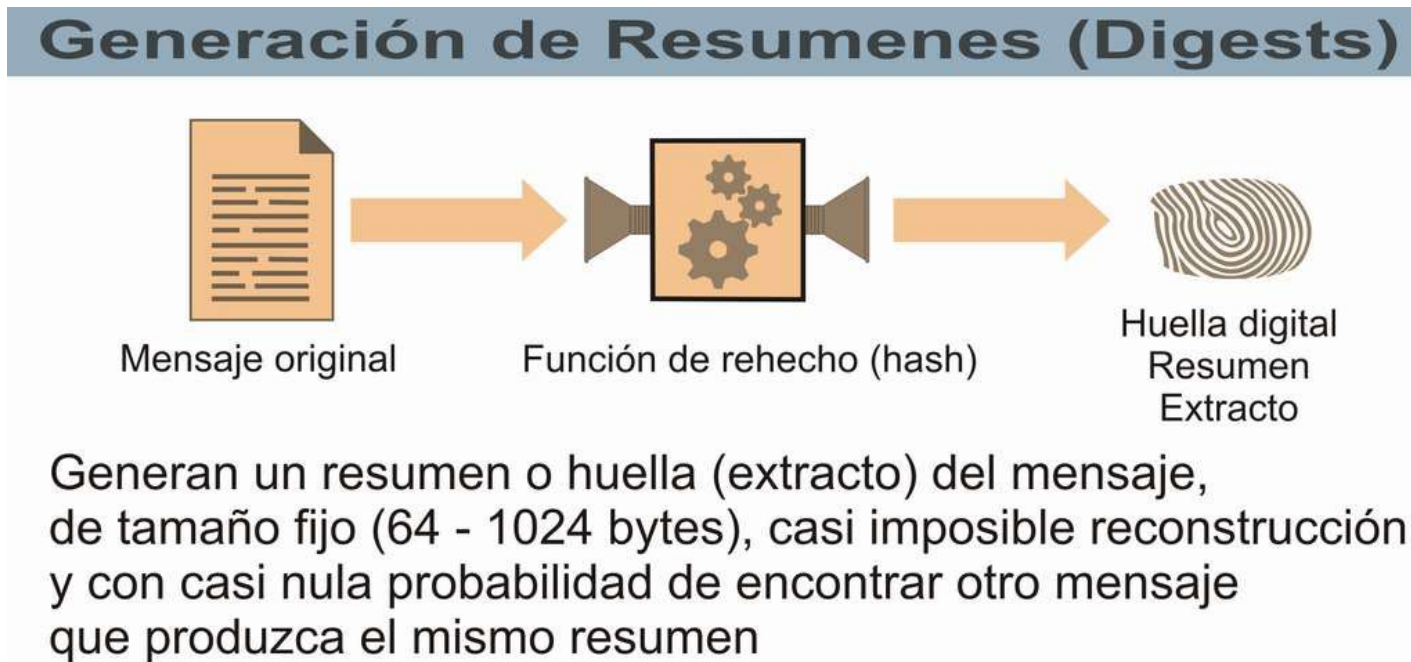
Números grandes – fuerza bruta – compromiso entre criptosistema y criptoanálisis

Teoría de la Información (Shannon) : Cantidad de Información – Entropía – Criptosistema seguro - Redundancia

Confusión (sustitución) y Difusión (trasposición)

Cifrado natural binario (Lorenz): XOR

Herramientas Básicas (1) – Integridad: Generación de Resúmenes



Algoritmos de Resumen

Los algoritmos utilizados han evolucionado desde la familia MD (MD2, MD3, MD4 y MD5), actualmente considerados poco seguros, a las familias SHA-1 (160 bits) , SHA-2 (256, 384 y 512) y SHA-3 (idem).

HOY: MDx y SHA-1 “rotos”, empleo de SHA-2 (SHA-256 SHA-384 y SHA-512) y SHA-3 en “reserva”.

Aplicaciones de los resúmenes:

1.- “Cifrado” de contraseñas (Windows, Linux, etc): En lugar de almacenar contraseñas, se almacenan los resúmenes ==> se compara con el resumen de la contraseña introducida por el usuario (**Autenticación**)

Sal: en vez de resumen(contraseña), se genera sal aleatoria y se almacena resumen(contraseña+sal) y sal

2.- Integridad de documentos: Se envía un documento (cifrado o no) y se adjunta su resumen. El receptor podrá calcular el resumen del documento recibido y cotejarlo (**Integridad**)

3.- Firma Digital: Cifrado con clave privada del “firmante”, del resumen de una clave pública, un certificado, un documento, etc. ==> Toda persona que conozca la clave pública del firmante podrá calcular el resumen con el mismo algoritmo y compararlo con el resultado de descifrar la firma con la clave pública. (**Autenticación, Integridad y No Repudio**)

4.- Firma de Claves – Cuando lo que se firma es una clave, se puede **transmitir la confianza** (evitación de ataques “man in the middle”)

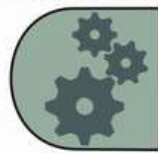
5.- Derivación de claves criptográficas – Iteración de resúmenes (contraseña+sal) - PBKDF1, PBKDF2, HKDF

6.- Autenticación de resúmenes – MAC – HMAC – se resume mensaje + contraseña

Herramientas Básicas (2) - Confidencialidad: clave simétrica

Algoritmos de Clave Simétrica

Proceso de
Generación



Clave Simétrica

Se genera aleatoriamente



+



=



Cualquier dato
Cifrado con la
Clave Simétrica

SOLO



+



=



puede ser
Descifrado con la
misma Clave
y viceversa

Tamaño de la Clave = variable (+ o - potencia) 56 - 256 (128) bits

Algoritmos = DES, RC2, TDES, IDEA, CAST, AES

Modos de operación = ECB, CBC, CFB

Algoritmos de cifrado simétrico

Algoritmos de cifrado simétrico en bloques (se especifica tamaño de clave, tamaño de bloque):

DES (1976) - 56,64 – IBM, NSA – sospechas claves débiles

Confusión (S-cajas) y Difusión (Redes de Feistel), resistente a cifrado de grupo

TDES (112/168,64) – cifrado, descifrado, cifrado con dos o tres claves DES

IDEA (1992) – (128,64) – XOR con subclaves y rondas de permutación (similar a RC5)

AES (2000) – (128/192/256,128) – S-cajas y rondas de permutación / sustitución

Cifrado en Bloques - Necesidad de modos de Operación:

Modo de operación en bloque (misma clave, padding): ECB (peligroso!) , CBC, PCBC

Modo de operación en flujo (necesidad vector Inicialización IV): CFB, OFB, CTR

Cifrado autenticado AEAD (combina modo de operación y autenticación) – GCM – Galois Counter Mode

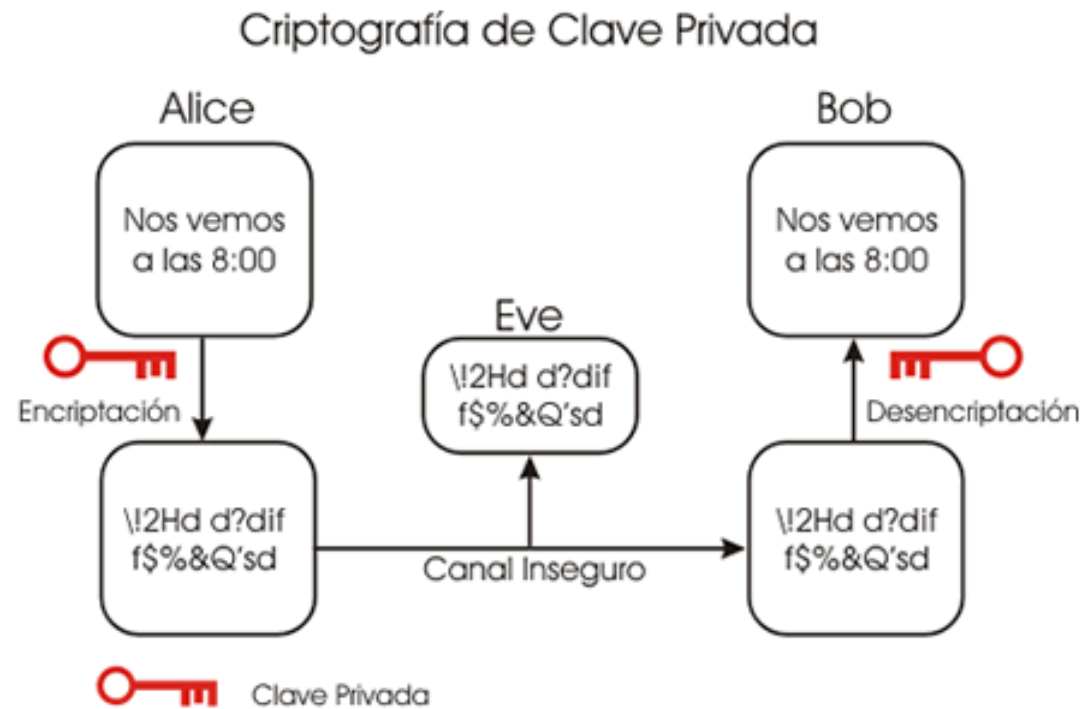
Cifrado en Flujo: generadores de secuencia (clave como semilla inicial) y XOR con plaintext

RC4 (variable, usado en WEP), Seal (variable), Salsa20, Chacha20 (128/256) y AEAD Poly-1305

Actualmente: AES 128/256 en modo CTR / CGM (se sigue usando CBC, CFB, CBC) y chacha20 / Poly-1305

TLS 1.3 sólo permite los cifradores AES-GCM, Chacha20-Poly1305 y GOST-MGM (2 bloque en flujo y 1 flujo)

Criptografía de Clave Privada o simétrica

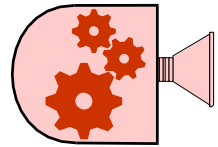


Problema: ¿Cómo hacemos llegar la clave al otro extremo?

Herramientas Básicas (3) - Compartición de secretos: clave asimétrica

Algoritmos de Clave Pública (Asimétrica)

Proceso de
Generación



Clave Privada

Siempre en poder
del usuario



Clave Pública

Horizontal: Servidores
Vertical: Certificados



+



=



Cualquier dato
Encriptado (Cifrado)
con la **Clave Pública**

SOLO



+



=



puede ser
Descifrado (Desencriptado)
con la **Clave Privada**
y viceversa

Tamaño de la Clave = 512, 1024, ... bits
Algoritmos = RSA, Diffie-Hellman

Algoritmos de clave pública (asimétrica)

Se basan en la aritmética modular, enteros grandes (300-8000 bits) y números primos – problemas difíciles

1.- Factorización:

RSA (1978, Patente->2000) – Dificultad de factorizar grandes números (1024/8192 bits) – cifrado y firma

2.- Problema del logaritmo discreto o PLD:

DH (1977, Patente -> 1997) – Negociación de secretos – en línea o mediante parejas de claves

ElGamal (1985, NO patente) – dos algoritmos (cifrado y firma) – incorporación a PGP

Schnorr (1989, Patente->2008) – Algoritmo de firma digital lineal y rápida – firma y verificación

DSA (1991, NSA) – Desarrollo NSA alternativo a Schnorr – no lineal y lento - firma y verificación

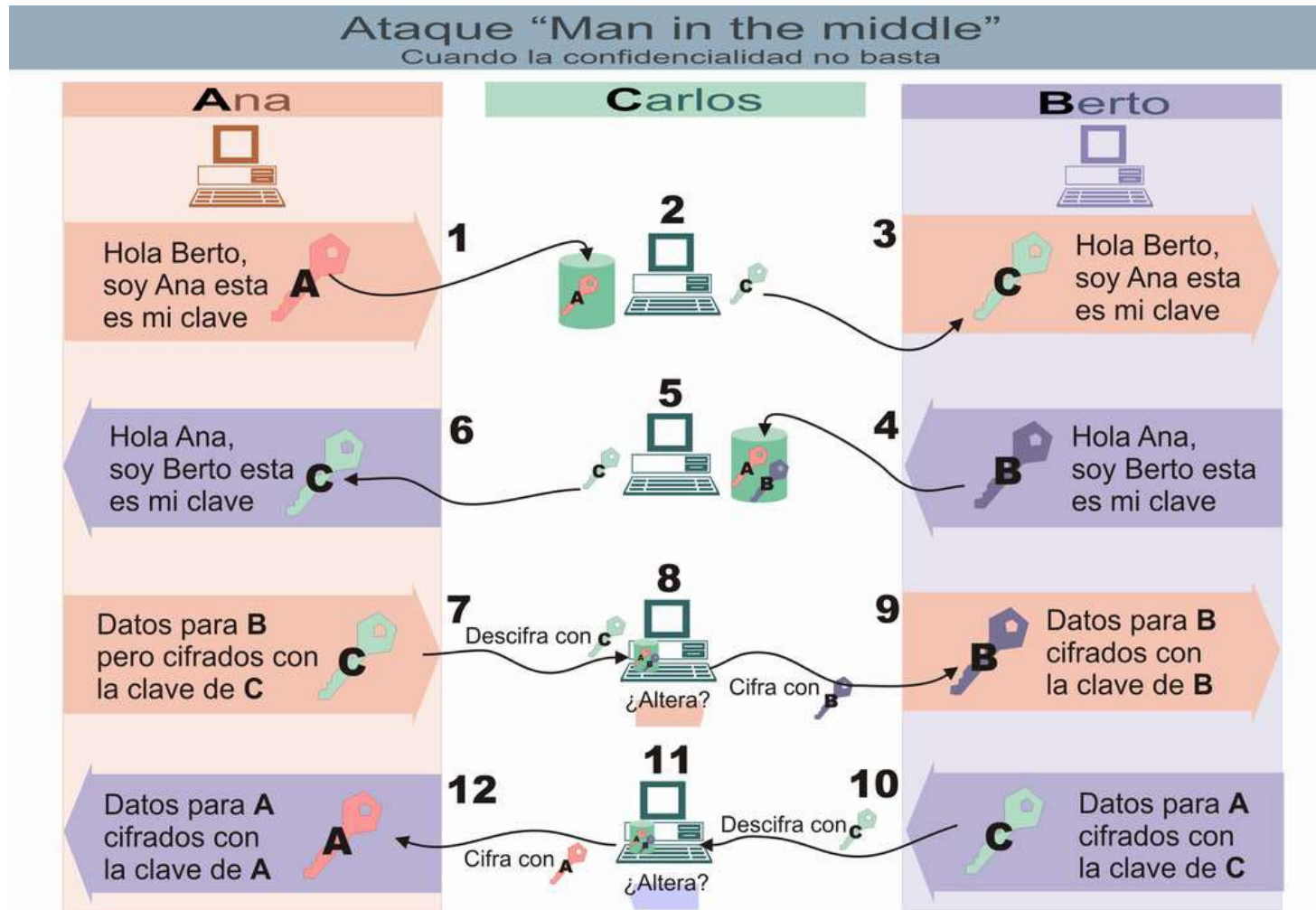
3.- PLD aplicado a **curvas elípticas** (ECDH, ECDSA, EdDSA, claves cortas – 200/800 bits – CURVAS)

Coste Computacional – Sistemas Mixtos

TDES-IDEA-RC5-AES para cifrado simétrico y RSA/ECDH para generación de secreto (HKDF para clave)

Debilidad: Posibilidad de ataque “Man in the Middle”

(intermediario que hace una doble suplantación entre los agentes que intercambian las claves de cifrado)



Solución: Integridad y Autenticación de las Claves Públicas – firma de claves

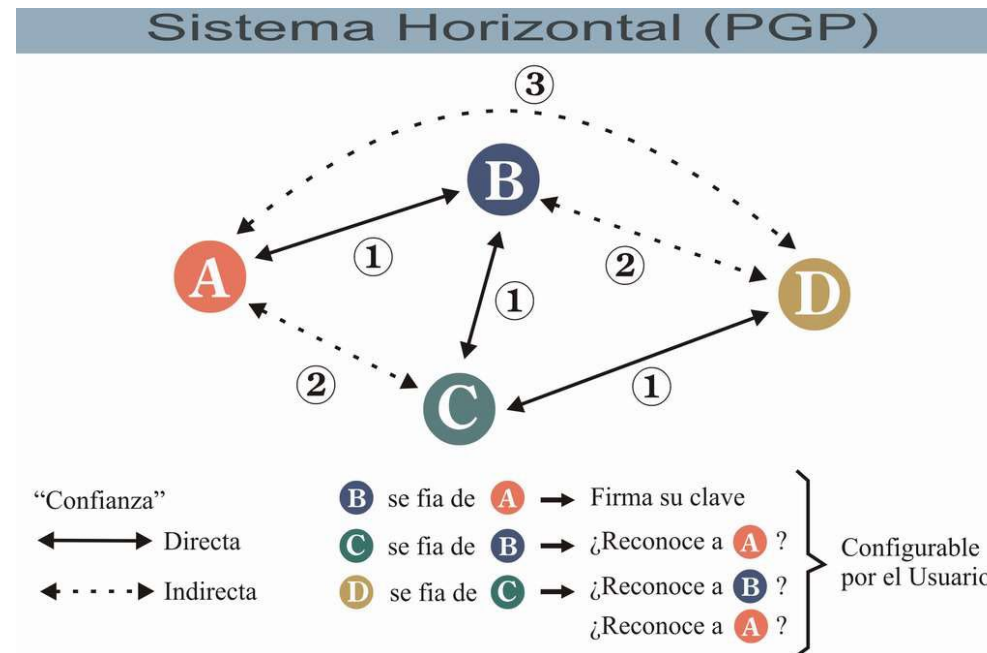
Lo que a su vez conducirá a la necesidad de elegir entre un sistema vertical u horizontal de establecimiento de confianza

La necesidad de firmar las claves de los agentes participantes de un sistema presenta dos alternativas:

- Sistemas **horizontales**: Todos los agentes tienen la misma confianza y se firman entre ellos
- Sistemas **verticales**: Se establecen “autoridades” que firman las claves de los demás agentes

SISTEMAS HORIZONTALES

Confianza entre Agentes, Transitividad, Telaraña de confianza (Web of Trust)



Ejemplos de Sistemas Horizontales: PGP, GnuPG, OpenPGP, SSH

Su uso a gran escala entre agentes que no se conocen requiere servidores de claves: poco fiables (claves falsas)

Sistemas verticales – Infraestructuras de clave pública (PKIs)

Basados en Cas – Autoridades de certificación que firman las claves de los restantes agentes

S/MIME, S-HTTP, SSL, TLS, SET, etc.

PKI: conjunto de CAs CRs Agentes (personas, dispositivos, programas, algoritmos, certificados, etc.)

Certificado Digital: estructura de datos

Versión: 1,2 o 3

Número de Serie:

Emisor de certificado:

Identificador de algoritmo usado en la firma:

RSA, DSA o CE

Periodo de Validez:

Nombre e información adicional del Sujeto:

Información de la clave pública del sujeto:

clave, longitud, y demás parámetros

Algunos datos opcionales:

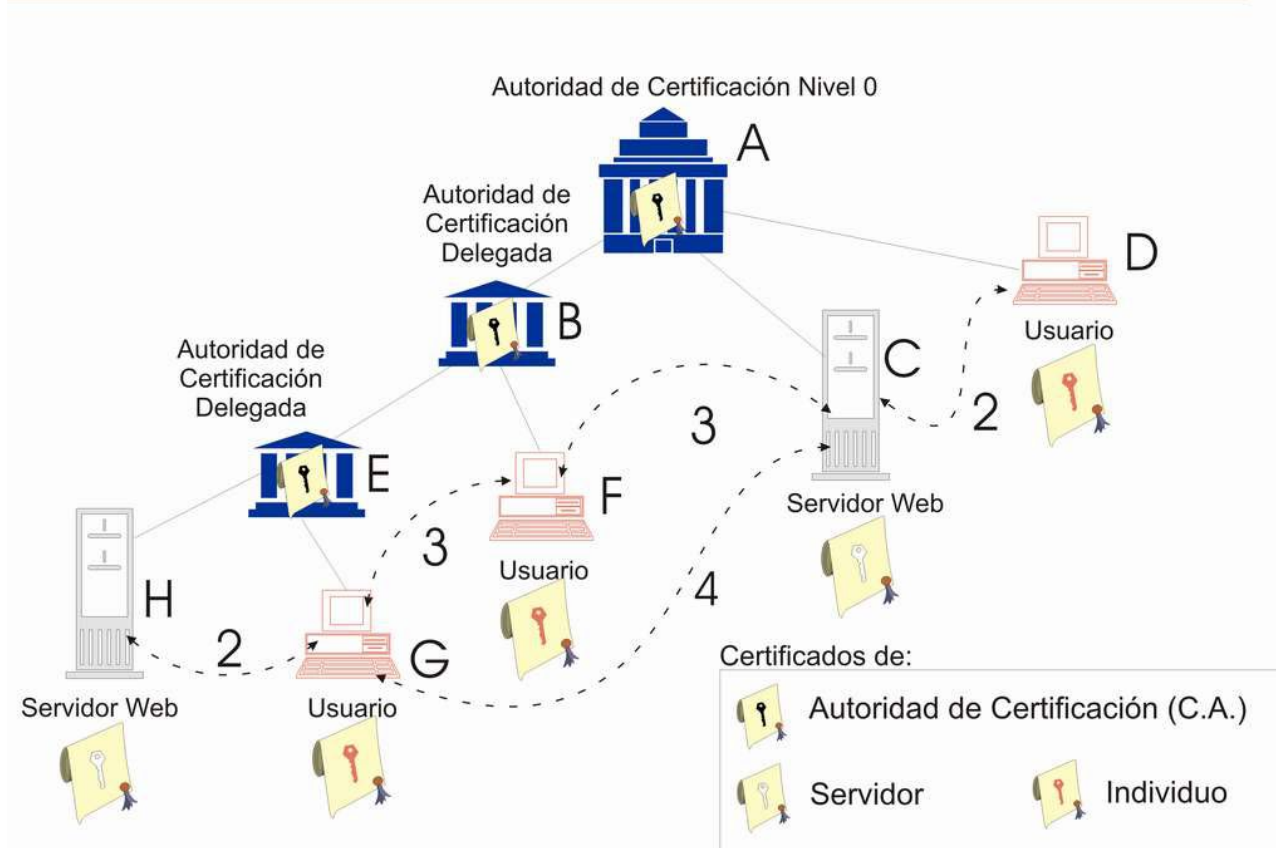
(por ejemplo, claves adicionales, operaciones autorizadas para cada clave, autoridad delegada de firma o registro, etc.)

Firma de la Autoridad Certificadora

X.509: formato estándar

Autoridades de certificación: niveles de autoridad

Esquema de Certificación en Modelo Vertical (SSL)



Autoridades delegadas: descentralizan y permiten minimizar el impacto de compromiso de la “root CA”

Renovación y revocación de certificados: CRLs y protocolos asociados (OSCP)

Tipos de Autoridades de Certificación

Certificados ==> Autoridad Certificación (CA) ==> Certificado Autofirmado (Raíz) =====> Necesidad Reconocimiento

Entornos Windows/Linux/Apple/Android/Navegadores ==> Almacén Certificados Raíz

Primera clasificación: Autoridades reconocidas y no reconocidas

- **CA/Browser Forum (cabforum.org) – Estándares y directrices garantizar confianza y seguridad**

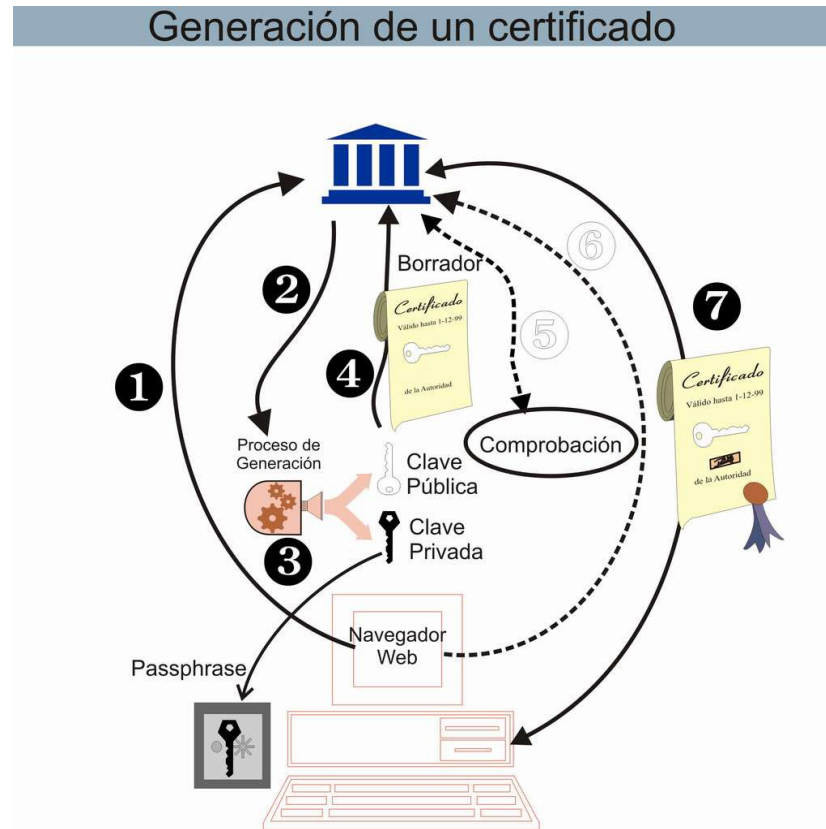
Segunda clasificación (ámbito de funcionamiento de las Autoridades):

- **Oficiales (gubernamentales y multinacionales) →** (DNIe, FNMT, etc) reconocidas en la mayoría de los almacenes estándar
- **Comerciales** (Thawte, Verisign, etc) → Empresas que emiten certificados para uso comercial
- **Gratuitas** (Let's Encrypt, Actalis) → Suelen no estar reconocidas, Let's Encrypt lo está y emite certificados web gratuitos reconocidos, actalis.it emite certificados S/MIME reconocidos (generación no segura)

Generación segura de certificados digitales

Inicialmente certificados ==> generados externamente ==> Problema confidencialidad

Firma electrónica avanzada ==> exige creación de la clave pública en el ordenador local



Problema de los certificados de software: protección de la clave privada (**firma avanzada**)

Solución: empleo de tarjetas criptográficas (DNIE): la clave privada nunca se expone (**firma reconocida**)

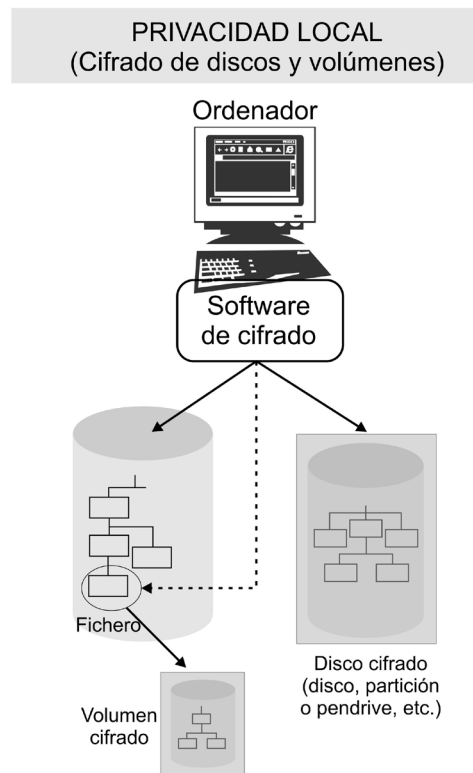
Actualmente (2026) Europa desarrollando "Wallet Digital" - obligatoriedad móvil Apple/Android?

SEGURIDAD DIGITAL EN ENTORNO LOCAL

Conceptos básicos de seguridad en ordenadores locales

Cifrado de contraseñas (resúmenes), Cifrado de claves (passphrases), etc

Cifrado de discos, volúmenes y ficheros



3 alternativas: Cifrado de Pendrives con hardware específico, de volúmenes de usuario o de discos de sistema

Seguridad en Wifi (Wireless Fidelity)

Irrupción Wifi en mercado doméstico (ADSL y fibra)

Carácter promiscuo redes “peer to peer” (Ethernet) – Mejoras tecnológicas (hubs ==> switches)

Redes Inalámbricas: Siempre son promiscuas y por tanto, inseguras

Pero: actualmente Wifi está desplazando a redes más seguras (Ethernet) → necesidad Wifi segura

Niveles de Seguridad. WEP, WPA, WPA2 y WPA3

WEP (Wired Equivalent Privacy): 1999. Actualmente obsoleto e **inseguro**

WPA (Wifi Protected Access): 2003. Mejoras WEP, vector inicialización, proceso de cifrado

2 modos de uso: Personal (contraseñas) y Empresarial (radius)

WPA2: 2004. Mejoras WPA (AES en lugar de RC4)

WPA3: 2018. Mejora negociación claves e integración dispositivos IoT

Seguridad Adicional:

Bloqueo de MACs, Ocultación del SSID, 802.X y Radius (Unidad 4)

!!!Cuidado con el protocolo WPS!!!

SEGURIDAD DIGITAL EN ENTORNO EXTENDIDO (WAN - Internet)

Aplicaciones de los sistemas horizontales

PGP, OpenPGP y GnuPG

PGP ==> PGP + PGPi (abierto) ==> obsolescencia PGPi ==> Desarrollo OpenPGP y GnuPG

Permiten cifrado simétrico, asimétrico (mixto) y firma digital de ficheros, aplicaciones básicas:

- **Cifrado de documentos y correo electrónico seguro** (PGP/Mime requisito para la comunicación de incidentes por correo a CERTS gubernamentales)
- **Firma de distribuciones de software abierto** (Linux, FreeBSD y sus aplicaciones)

Cifrado de conexiones entre máquinas. SSH (Secure Shell)

Internet ==> disponibilidad telnet, ftp, rlogin ==> inseguros (contraseñas en texto claro)

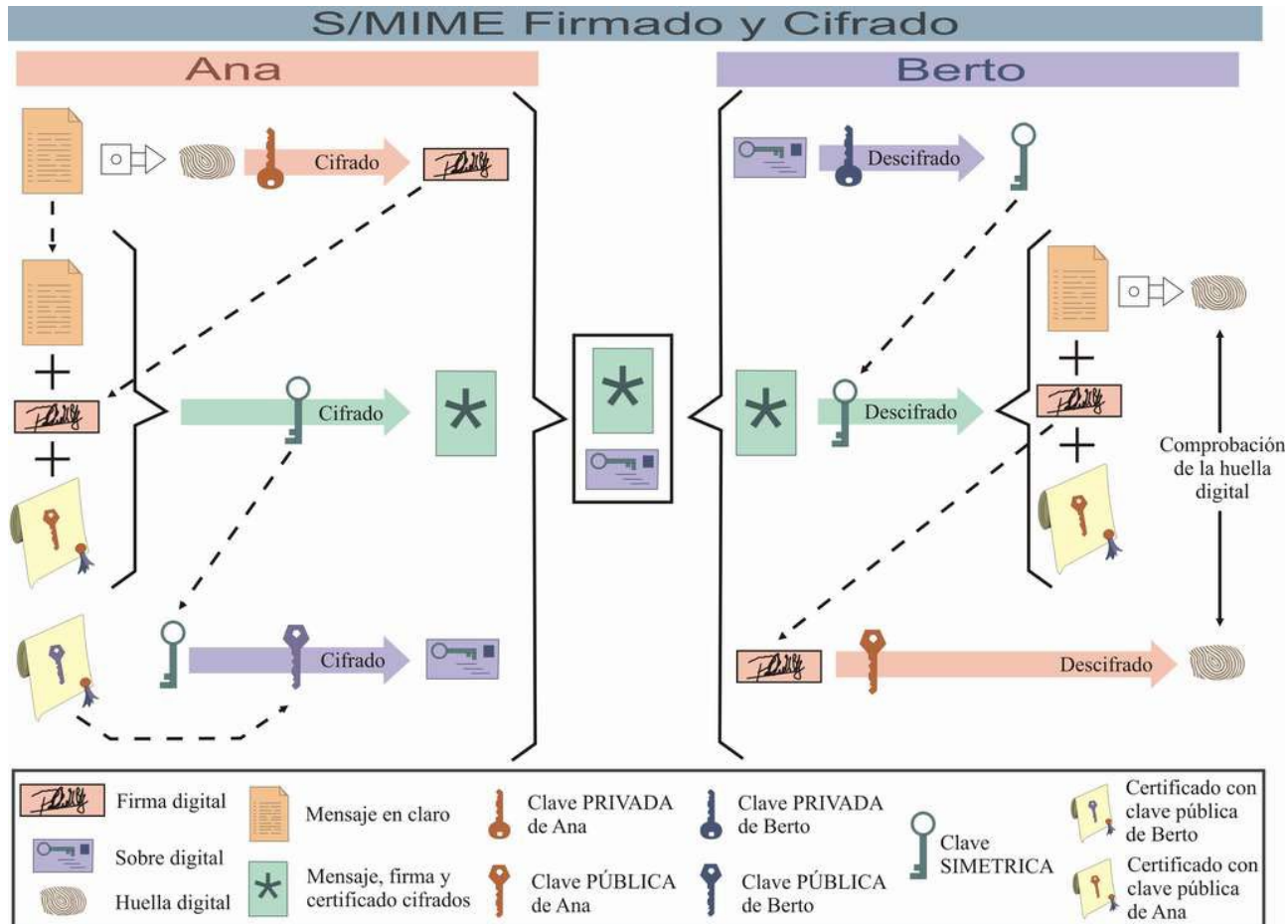
SSH ==> reemplazo rlogin, telnet, ftp y rsh por versiones cifradas usando claves públicas en sistema horizontal

OpenSSH (abierto) – empleo universal para conexión segura entre equipos (clientes con servidores)

Aplicaciones de los sistemas verticales

Seguridad en el software. Firmado de software propietario (Apple, Microsoft, etc.)

Correo Electrónico Seguro (S/MIME)



SSL y TLS. Cifrado de conexiones Internet

SSL(Secure Socket Layer) ==> Desarrollado por Netscape (cifrado de conexiones en sistema vertical)

SSL V3.0 equivale a TLS (Transport Level Security) V1.0 ➔ **obsoletos** (TLS V1.1 mínimo)

Mientras que SSH provee seguridad entre componentes software en un sistema horizontal, TLS provee una “capa segura” entre transporte y aplicación sobre sistema vertical

Operaciones:

- Negociar algoritmos de cifrado (AES, Chacha20, etc.) y de resumen (SHA-2)
- Intercambio de claves públicas (RSA, DH, DSA, ECDH, ECDSA, etc.) y autenticación basada en certificados
- Cifrado simétrico del tráfico

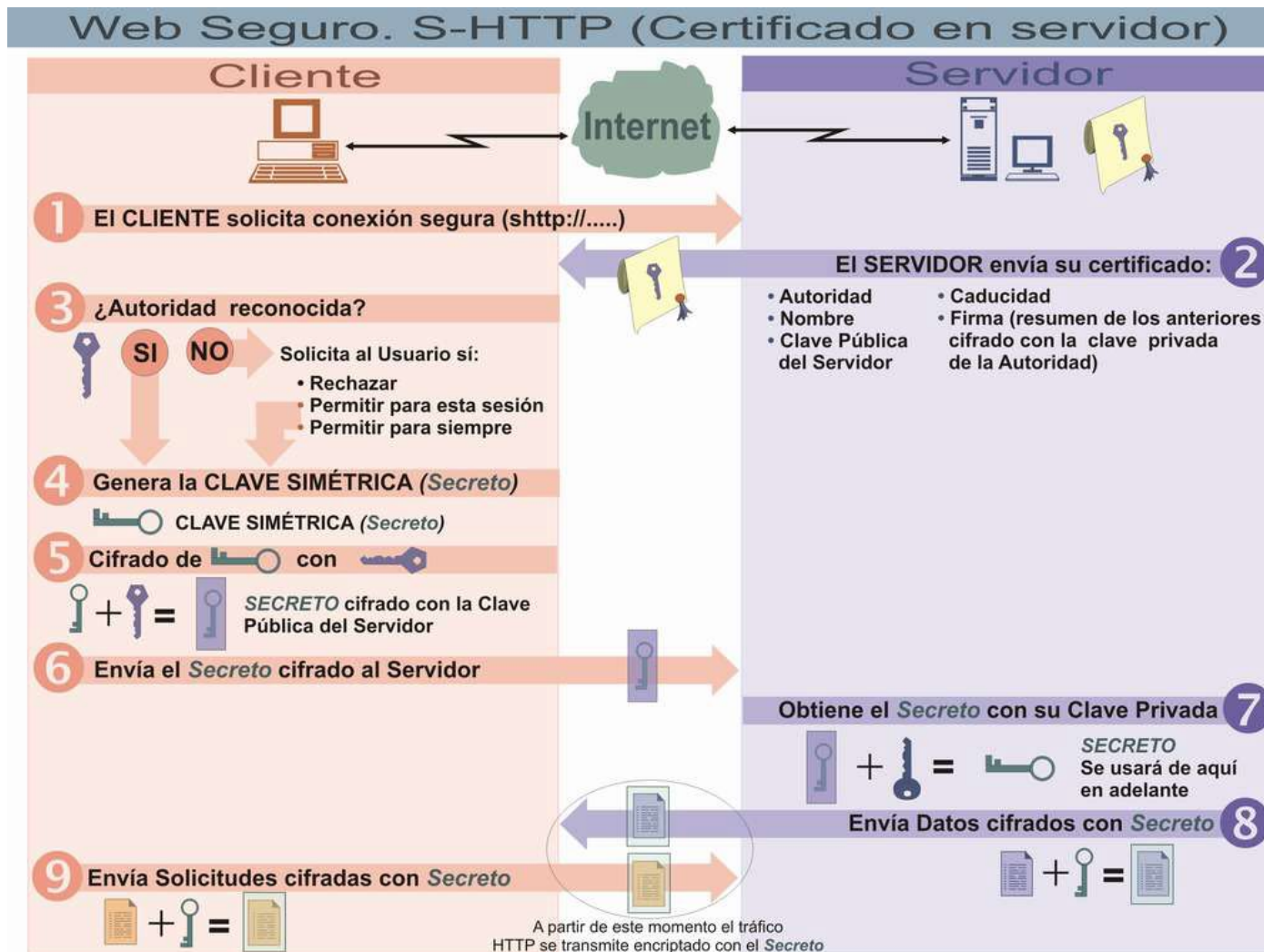
Dos modos de funcionamiento:

- Sólo una de las partes posee certificado (usualmente servidor)
- Ambas partes poseen certificado: doble autenticación, posibilidad evitar uso contraseñas identificación

Actualmente: Transición desde TLS 1.2 a TLS 1.3:

- Sólo AES-GCM, Chacha20-Poly1305 y GOST como cifradores simétricos permitidos
- Eliminación de varios algoritmos asimétricos en modo “Anonymous”

TLS sobre HTTP. Web segura HTTPS con certificado en el Servidor



Los pasos 4-7 pueden ser (SON) reemplazados por una negociación de claves Diffie-Hellman (ECDH)

Posibilidad: Uso de certificados en ambos extremos, evitación de usuario y contraseña de acceso (bancos, etc.)

Otras Aplicaciones. IP segura y túneles cifrados. Redes Privadas Virtuales (VPN)

SSH funciona a nivel de aplicación (entre programas)

TLS implementa un transporte seguro (hace segura una capa de la red)

Alternativa: Implantar seguridad a nivel de paquetes de red

Protocolo IPSec:

3 componentes: **AH (Authentication Header)** **ESP (Encapsulating Security Payload** - Cifrado de la carga útil de los paquetes IP) e **IKE (Internet Key Exchange)** para negociación de claves - Intercambio de certificados entre los extremos, creación y transmisión segura del “secreto”.

Permite **modo transporte** (cifrado de paquetes IP) y **modo túnel** (IP dentro de IP) red-red o usuario-red (VPN)

Túneles Cifrados:

Posibilidad de cifrar todo el tráfico entre subredes

VPNs (Virtual Private Networks) - OpenVPN, etc y WireGuard:

Paquetes cifrados “privados” dentro de paquetes “públicos”

Posibilidad de acceso a redes seguras desde redes inseguras

OpenVPN y similares utilizan TLS (TCP/UDP); **WireGuard** usa protocolos fijos, implantado kernel Linux.

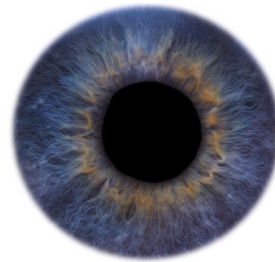
HERRAMIENTAS ADICIONALES EN SEGURIDAD DIGITAL

Biometría:

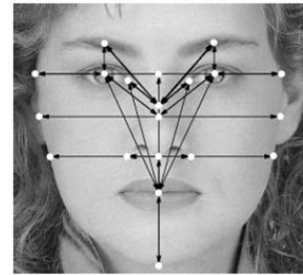
Métodos para el reconocimiento automático de seres vivos mediante el análisis de rasgos fisiológicos o rasgos de conducta (**algo que se es**)

Usualmente: **Identificación** o como **segundo factor de autenticación**

DNLe: Datos biométricos (recuperación de la contraseña)



Iris



Cara



Huella Dactilar



Palma de la Mano

Biometría. Características Fisiológicas para la Identificación de Usuarios.

Esteganografía:

Mecanismos para la transmisión de mensajes, o el almacenamiento de información, de manera que esta pase inadvertida y oculta a todos, excepto a los agentes involucrados en la comunicación

Se basa en **seguridad** a través de la **oscuridad** y por tanto **no son estándares** en seguridad de la información

Versión Digital: enmascaramiento de datos (usualmente cifrados) en imágenes, vídeos, etc. y “marcas de agua”.